

Third-Party Vendor Risk Policy

Synthetic policy for local retrieval and citation demos

Policy ID	TPRM-POL-005
Owner	Third-Party Risk Management
Effective Date	2026-03-12
Review Cycle	Annual

Document Summary

Defines vendor risk tiers, approval thresholds, due diligence evidence, contract controls, and ongoing monitoring requirements.

This document is fictional and contains no real client, employee, vendor, or confidential enterprise information.

1. Purpose and Scope

This policy establishes risk-based controls for selecting, approving, contracting with, and monitoring third-party vendors in fictional enterprise workflows.

The policy applies to vendors, consultants, software providers, managed service providers, data processors, cloud services, subcontractors with material access, and any third party supporting a critical business process.

2. Risk Tiers

Vendors are classified as Critical, High, Moderate, or Low risk based on data access, business criticality, regulatory relevance, operational substitutability, financial exposure, geographic risk, and concentration risk.

Critical vendors support essential services where failure could materially disrupt client service, regulatory obligations, payment operations, security operations, or financial reporting. High-risk vendors access Confidential or Restricted data, host production systems, or support important control processes.

3. Approval Thresholds

Low-risk vendors may be approved by the business owner after basic screening and procurement review.

Moderate-risk vendors require Third-Party Risk Management review and business owner approval.

High-risk vendors require Security, Privacy, Legal, Procurement, and Third-Party Risk Management approval before contract signature. Critical vendors require executive sponsor approval and review by the Vendor Risk Committee.

No vendor may receive production credentials, client data, or network access before all required approvals are complete and recorded in the vendor inventory.

4. Due Diligence Evidence

Due diligence may include security questionnaire, SOC 2 or equivalent assurance report, penetration test summary, financial health review, privacy assessment, business continuity evidence, insurance certificate, sanctions screening, and subcontractor list.

For vendors using AI or analytics on enterprise data, the assessment must include model purpose, data retention, training use restrictions, human review controls, explainability where applicable, and incident notification commitments.

5. Contract Controls

Contracts for High and Critical vendors must include confidentiality obligations, data processing terms, audit rights, breach notification timelines, subcontractor controls, service level expectations, termination assistance, and secure deletion requirements.

Vendors handling Restricted data must agree not to use enterprise data for model training, product improvement, or secondary purposes unless explicitly approved by the data owner and Legal.

6. Ongoing Monitoring

Critical vendors must be reviewed at least annually, High-risk vendors at least annually, Moderate-risk vendors every two years, and Low-risk vendors at renewal or when a material change occurs.

Material issues, missed service levels, security incidents, ownership changes, financial distress, or unapproved subcontracting must be escalated to Third-Party Risk Management within five business days.